

Minimum Security Baseline (MSB) for Software Embedded in Space Systems

Based on ECSS-Q-ST-80-10C, NIST.SP.800-53r5, CCSDS Magenta and CCSDS Blue standards
(some text was generated by LLM GPT type AI, specifically chatGPT)

Reference Standards..... 2

Communication Requirements..... 3

IoT Ecosystem Requirements..... 5

Software Platform Requirements..... 6

User Space Application Requirements..... 8

Version control

Version	Issued date	Description
0.0.1	May, 2025	First published result of a comparison between standards, using OWASP ISVS (Pre-release 1.0RC) as ontology base.

Reference Standards

The following normative documents were harmonized in order to generate a minimum product common to all of them, called Minimum Security Baseline. All of these mentioned below were used in their latest available versions.

<i>CCSDS Blue Books</i>	<i>352.0-B-2 - CCSDS Cryptographic Algorithms</i>
	<i>355.0-B-2 - Space Data Link Security Protocol</i>
	<i>357.0-B-1 - Authentication Credentials</i>
<i>CCSDS Magenta Books</i>	<i>351.0-M-1 - Security Architecture For Space Data Systems</i>
	<i>354.0-M-1 - Symmetric Key Management</i>
<i>ECSS-E-ST-80C</i>	<i>Space engineering - Security in space systems lifecycles</i>
<i>NIST Special Publication 800-53 Revision 5</i>	<i>Security and Privacy Controls for Information Systems and Organizations</i>

Communication Requirements

CR-1 Cryptographic keys — generation, distribution, protection

The mission **shall** generate (from an approved source), distribute, store, rotate, audit-log and finally destroy all master, session and certificate keys in accordance with the CCSDS key-lifecycle, using NIST-approved algorithms, so that every space-link frame and ground packet protected under ECSS 5.2.2 attains confidentiality, integrity and authenticity.

CR-2 Authenticated identity & attribute-based flow control

Every command or data flow **shall** be accepted or delivered only when the sending entity presents a valid CCSDS credential whose attributes match the Security-Association policy; enforcement is cryptographic (ICV) at frame level and implements least-privilege / need-to-know across space and ground segments.

CR-3 Authorisation of external connections and services

Prior to operation the project **shall** risk-assess and formally authorise every ground-segment, launch-segment or cross-support interface, bind it to a Security-Association, log its use, and require external providers to honour the same cryptographic controls and audits defined for mission-internal links.

CR-4 Continuous security monitoring & incident handling

The mission **shall** collect, protect and analyse security telemetry from space and ground components, including crypto-key events and protocol error counters; run scheduled audits, vuln-scans and pen-tests; and execute an incident-response process that contains, eradicates and recovers from security events while preserving forensics.

CR-5 Supply-chain assurance

- a. Require that providers of external system services comply with organizational security and privacy requirements and employ the following controls: [Assignment: organization-defined controls];
- b. Define and document organizational oversight and user roles and responsibilities with regard to external system services; and
- c. Employ the following processes, methods, and techniques to monitor control compliance by external service providers on an ongoing basis: [Assignment: organization-defined processes, methods, and techniques].

1) EXTERNAL SYSTEM SERVICES | RISK ASSESSMENTS AND ORGANIZATIONAL APPROVALS

(a) Conduct an organizational assessment of risk prior to the acquisition or outsourcing of information security services; and

(b) Verify that the acquisition or outsourcing of dedicated information security services is approved by [Assignment: organization-defined personnel or roles].

(2) EXTERNAL SYSTEM SERVICES | IDENTIFICATION OF FUNCTIONS, PORTS, PROTOCOLS, AND SERVICES

Require providers of the following external system services to identify the functions, ports, protocols, and other services required for the use of such services: [Assignment: organization-defined external system services].

(3) EXTERNAL SYSTEM SERVICES | ESTABLISH AND MAINTAIN TRUST RELATIONSHIP WITH PROVIDERS

Establish, document, and maintain trust relationships with external service providers based on the following requirements, properties, factors, or conditions: [Assignment: organization-defined security and privacy requirements, properties, factors, or conditions defining acceptable trust relationships].

(4) EXTERNAL SYSTEM SERVICES | CONSISTENT INTERESTS OF CONSUMERS AND PROVIDERS

Take the following actions to verify that the interests of [Assignment: organization-defined external service providers] are consistent with and reflect organizational interests: [Assignment: organization-defined actions].

(5) EXTERNAL SYSTEM SERVICES | PROCESSING, STORAGE, AND SERVICE LOCATION

Restrict the location of [Selection (one or more): information processing; information or data; system services] to [Assignment: organization-defined locations] based on [Assignment: organization-defined requirements or conditions].

(6) EXTERNAL SYSTEM SERVICES | ORGANIZATION-CONTROLLED CRYPTOGRAPHIC KEYS

Maintain exclusive control of cryptographic keys for encrypted material stored or transmitted through an external system.

(7) EXTERNAL SYSTEM SERVICES | ORGANIZATION-CONTROLLED INTEGRITY CHECKING

Provide the capability to check the integrity of information while it resides in the external system.

(8) EXTERNAL SYSTEM SERVICES | PROCESSING AND STORAGE LOCATION — U.S. JURISDICTION

Restrict the geographic location of information processing and data storage to facilities located within in the legal jurisdictional boundary of the United States.

The supplier shall define and implement processes and technical measures to ensure and verify at any phase of the project the authenticity of a service, component or a subsystem across the whole supply chain.

Supplier shall implement product assurance requirements considering ECSS-Q-ST-10.

The system security engineering requirements which have been derived in the frame of the project shall be flown-down to the relevant suppliers of security sensitive products and considering also ECSS-Q-ST-80 and ECSS-E-ST-40 if the supplies contain software modules.

The supplier shall assess potential vendors, taking into account the criticality and sensitivity of the product or service to determine if they:

- Provide products and components, or sub-components, sourced through original equipment manufacturers or authorized resellers with clear and traceable bill of materials with appropriate integrity and authenticity measures.

- Have previously incurred significant malicious network intrusions, data breaches, loss of client data, or intellectual property.

- Have an adequately mature cyber security organisation, appropriate certifications and qualifications.

- Provide services and products compliant to national regulations.

The customer shall define the supplier privacy and system security engineering requirements based on the criticality and sensitivity of the asset, resource or services to be provided by the supplier.

The supplier shall provide a statement of compliance against the requirement set identified in accordance with 5.3.3b and 5.3.3c (ECSS-E-ST-80) with supporting credible evidence.

Supply chain management and requirements shall be defined and implemented at each level of the customer-supplier network.

Supply chain management and requirements shall be defined in Supply Chain Management Plan.

CR-6 Protocol-layer cryptographic implementation

Security header (SA-ID, crypto-offset) and trailer (ICV) are inserted between CCSDS frame header & trailer to provide authentication and/or confidentiality.

Detailed format and processing rules for TM, TC, AOS and USLP transfer-frames, including baseline field layouts in Annex E (CCSDS 355.0-B-2 - SPACE DATA LINK SECURITY PROTOCOL)

IoT Ecosystem Requirements

CR-1 – Policies, procedures and security planning

The organisation **shall** create, approve, disseminate and periodically update a coherent set of security-related policies, procedures and a System Security & Privacy Plan that (1) cover access control, auditing, assessment/authorisation/monitoring and software life-cycle activities, (2) embed those controls in acquisition and development contracts (including supply-chain agreements), and (3) assign clear roles and review cycles.

CR-2 – Audit-logging discipline

The system **shall** capture a time-stamped audit record for each defined security-relevant event, including the type of event, the user or process identity and the result, using a synchronised time source, and **shall** retain those records for the period specified in the System Security Plan to support forensic investigation and corrective action.

CR-3 – Approved cryptographic algorithms

- 1) Approved symmetric algorithm is AES with 128/192/256-bit keys operated in CTR or CBC mode.
- 2) Authenticated encryption shall use AES-GCM.
- 3) Message authentication shall use HMAC-SHA-256 or CMAC-AES; digital signatures shall use ECDSA P-256

CR-4 – Master-key definition & hierarchy

Master Keys shall be used only to encrypt, authenticate or derive Session Keys; a specific Master Key shall be used for only one such purpose during its lifetime and shall be rotated or deactivated at the end of that lifetime

CR-5 – Plan-of-action / remediation tracking

The organisation develops and implements Plans of Action & Milestones for all security and privacy deficiencies, documents the resources required to correct the deficiencies, and tracks the progress of corrective actions to completion.

Software Platform Requirements

CR-1 Least-Privilege access enforcement

“The system **enforces least privilege** by *‘allocating access permissions based on duties and limiting access to the minimum necessary’* (NIST AC-6). Access decisions **shall be role-based** so that *‘privilege is associated with roles, not with identities’* (NIST AC-3 (10)). Design *‘shall implement least-privilege so every process operates with only the privileges strictly required’* (ECSS 4.1.7).

CR-2 Audit log generation, protection & review

“Generate audit records for the events the organisation deems significant” (NIST AU-2) and **protect, retain and review** them per AU-5, -7, -9. ECSS requires *‘security monitoring and incident handling shall include the collection, protection and analysis of security logs’* (§5.2.3) and *‘periodic security audits of recorded events’* (§5.4.3). Therefore: **The mission shall produce, protect, retain and continuously review audit records covering the events listed in AU-2 and ECSS §5.2.3.**

CR-3 Ongoing security assessment & penetration testing

“Assess security controls at least annually” (NIST CA-2) and implement continuous monitoring (CA-7); “Conduct independent penetration testing” (CA-8). ECSS §5.4.1 adopts the same risk-based cycle, and §5.4.5 mandates pen-testing. ⇒ Plan, execute and track periodic control assessments and independent penetration tests; feed results into the risk-management process.

CR-4 Authorised security configuration baseline

NIST CM-2/-3 require documented baselines and formal change control; CM-5/-7 add *deny-by-exception* and execution-restriction; CM-14 mandates “scanning for unauthorised modifications”. ECSS §5.3.2 e–f demands the same for space-system security items. Maintain an approved security-configuration baseline; detect, block and record unauthorised change; update the baseline through the formal change-process only.

CR-5 Documented security architecture & plan

NIST PL-8: “develop, document, and maintain a security architecture ... integrated with enterprise architecture.” ECSS §5.3: “A System-Security Engineering Plan shall define the architecture, trust boundaries and security measures.” Therefore a single integrated Security Architecture / Plan shall be established and baselined.

CR-6 Secure acquisition & supply-chain assurance

NIST SA-4 (acquisition contracts to state security requirements), SA-8 (SCRM plan) & SA-15 (development process) align with ECSS §5.3.3 Supply-chain requirements: *“suppliers shall implement tamper evidence, secure transport, and pedigree for critical components.”*

CR-7 Cryptography & key-management for space links

NIST SC-32 (cryptographic key establishment) and SC-34 (prevent message replay) state the functional need. CCSDS gives the concrete profile: CCSDS 352 (§3 AES-GCM, CMAC, key sizes); CCSDS 354 (§3 key types & lifecycle); CCSDS 355 (§3–§4 protocol header/trailer, anti-replay counters; §6.2 managed parameters).

CR-8 Vulnerability detection, remediation & software integrity

The software project shall identify, assess and remediate vulnerabilities; verify code integrity before execution; block malicious code; validate external inputs.

CR-9 Attack-surface reduction & defence-in-depth

“Design shall minimise the exposed attack surface” (ECSS 4.1.2) and “apply defence-in-depth by layering security controls” (4.1.4).

User Space Application Requirements

Cryptographic algorithm strength

All confidentiality or authenticated-encryption functions **shall use AES (128/192/256) in NIST/CCSDS-approved modes**; integrity/MAC functions **shall use SHA-2 HMAC or AES-CMAC**.

Key-length & key-life

Symmetric keys **shall be ≥ 128 bits and have an approved maximum operational lifetime commensurate with the mission risk assessment.**

Key hierarchy & key-wrapping

A hierarchical scheme **shall be used in which master keys encrypt or authenticate session keys during OTAR; key-wrap/authenticated-encryption approved in CR-1 shall be applied.**

Credential format

Device & user credentials **shall be X.509 v3 certificates packaged in PKCS #12**, signed with an approved algorithm (CR-1) and time-stamped per CCSDS calendar segmented time code.

Mutual entity authentication

Interactive access **shall implement cryptographic challenge–response authentication**; when a PKI is available use X.509 (CR-4); otherwise use protected-simple-authentication with one-way-function password protection.

Audit & accountability

AU-6 AUDIT RECORD REVIEW, ANALYSIS, AND REPORTING

Control:

- a. Review and analyze system audit records [Assignment: organization-defined frequency] for indications of [Assignment: organization-defined inappropriate or unusual activity] and the potential impact of the inappropriate or unusual activity;
- b. Report findings to [Assignment: organization-defined personnel or roles]; and
- c. Adjust the level of audit record review, analysis, and reporting within the system when there is a change in risk based on law enforcement information, intelligence information, or other credible sources of information.

Control Enhancements:

(1) AUDIT RECORD REVIEW, ANALYSIS, AND REPORTING | AUTOMATED PROCESS INTEGRATION

Integrate audit record review, analysis, and reporting processes using [Assignment: organization-defined automated mechanisms].

(3) AUDIT RECORD REVIEW, ANALYSIS, AND REPORTING | CORRELATE AUDIT RECORD REPOSITORIES

Analyze and correlate audit records across different repositories to gain organization-wide situational awareness.

(4) AUDIT RECORD REVIEW, ANALYSIS, AND REPORTING | CENTRAL REVIEW AND ANALYSIS

Provide and implement the capability to centrally review and analyze audit records from multiple components within the system.

(5) AUDIT RECORD REVIEW, ANALYSIS, AND REPORTING | INTEGRATED ANALYSIS OF AUDIT RECORDS

Integrate analysis of audit records with analysis of [Selection (one or more): vulnerability scanning information; performance data; system monitoring information; [Assignment: organization-defined data/information collected from other sources]] to further enhance the ability to identify inappropriate or unusual activity.

(6) AUDIT RECORD REVIEW, ANALYSIS, AND REPORTING | CORRELATION WITH PHYSICAL MONITORING

Correlate information from audit records with information obtained from monitoring physical access to further enhance the ability to identify suspicious, inappropriate, unusual, or malevolent activity.

(7) AUDIT RECORD REVIEW, ANALYSIS, AND REPORTING | PERMITTED ACTIONS

Specify the permitted actions for each [Selection (one or more): system process; role; user] associated with the review, analysis, and reporting of audit record information.

(8) AUDIT RECORD REVIEW, ANALYSIS, AND REPORTING | FULL TEXT ANALYSIS OF PRIVILEGED COMMANDS

Perform a full text analysis of logged privileged commands in a physically distinct component or subsystem of the system, or other system that is dedicated to that analysis.

(9) AUDIT RECORD REVIEW, ANALYSIS, AND REPORTING | CORRELATION WITH INFORMATION FROM NONTECHNICAL SOURCES

Correlate information from nontechnical sources with audit record information to enhance organization-wide situational awareness.

(10) NON-REPUDIATION

Control: Provide irrefutable evidence that an individual (or process acting on behalf of an individual) has performed [Assignment: organization-defined actions to be covered by non-repudiation].

(11) NON-REPUDIATION | ASSOCIATION OF IDENTITIES

(a) Bind the identity of the information producer with the information to [Assignment: organization-defined strength of binding]; and

(b) Provide the means for authorized individuals to determine the identity of the producer of the information.

(12) NON-REPUDIATION | VALIDATE BINDING OF INFORMATION PRODUCER IDENTITY

(a) Validate the binding of the information producer identity to the information at

[Assignment: organization-defined frequency]; and

(b) Perform [Assignment: organization-defined actions] in the event of a validation error.

(13) NON-REPUDIATION | CHAIN OF CUSTODY

Maintain reviewer or releaser credentials within the established chain of custody for information reviewed or released.

(14) NON-REPUDIATION | VALIDATE BINDING OF INFORMATION REVIEWER IDENTITY

(a) Validate the binding of the information reviewer identity to the information at the transfer or release points prior to release or transfer between [Assignment: organization-defined security domains]; and

(b) Perform [Assignment: organization-defined actions] in the event of a validation error.

Account management & provisioning

ACCOUNT MANAGEMENT

Control:

a. Define and document the types of accounts allowed and specifically prohibited for use within the system;

b. Assign account managers;

c. Require [Assignment: organization-defined prerequisites and criteria] for group and role membership;

d. Specify:

1. Authorized users of the system;

2. Group and role membership; and

3. Access authorizations (i.e., privileges) and [Assignment: organization-defined attributes (as required)] for each account;

e. Require approvals by [Assignment: organization-defined personnel or roles] for requests to create accounts;

f. Create, enable, modify, disable, and remove accounts in accordance with [Assignment: organization-defined policy, procedures, prerequisites, and criteria];

g. Monitor the use of accounts;

h. Notify account managers and [Assignment: organization-defined personnel or roles] within:

1. [Assignment: organization-defined time period] when accounts are no longer required;

2. [Assignment: organization-defined time period] when users are terminated or transferred; and

3. [Assignment: organization-defined time period] when system usage or need-to-know changes for an individual;

i. Authorize access to the system based on:

1. A valid access authorization;

- 2. Intended system usage; and
- 3. [Assignment: organization-defined attributes (as required)];
- j. Review accounts for compliance with account management requirements [Assignment: organization-defined frequency];
- k. Establish and implement a process for changing shared or group account authenticators (if deployed) when individuals are removed from the group; and
- l. Align account management processes with personnel termination and transfer processes.

Control Enhancements:

(1) ACCOUNT MANAGEMENT | AUTOMATED SYSTEM ACCOUNT MANAGEMENT
Support the management of system accounts using [Assignment: organization-defined automated mechanisms].

(2) ACCOUNT MANAGEMENT | AUTOMATED TEMPORARY AND EMERGENCY ACCOUNT MANAGEMENT
Automatically [Selection: remove; disable] temporary and emergency accounts after [Assignment: organization-defined time period for each type of account].

(3) ACCOUNT MANAGEMENT | DISABLE ACCOUNTS
Disable accounts within [Assignment: organization-defined time period] when the accounts:
(a) Have expired;
(b) Are no longer associated with a user or individual;
(c) Are in violation of organizational policy; or
(d) Have been inactive for [Assignment: organization-defined time period].

(4) ACCOUNT MANAGEMENT | AUTOMATED AUDIT ACTIONS
Automatically audit account creation, modification, enabling, disabling, and removal actions.

(5) ACCOUNT MANAGEMENT | INACTIVITY LOGOUT
Require that users log out when [Assignment: organization-defined time period of expected inactivity or description of when to log out].

(6) ACCOUNT MANAGEMENT | DYNAMIC PRIVILEGE MANAGEMENT
Implement [Assignment: organization-defined dynamic privilege management capabilities].

(7) ACCOUNT MANAGEMENT | PRIVILEGED USER ACCOUNTS
(a) Establish and administer privileged user accounts in accordance with [Selection: a role-based access scheme; an attribute-based access scheme];
(b) Monitor privileged role or attribute assignments;
(c) Monitor changes to roles or attributes; and
(d) Revoke access when privileged role or attribute assignments are no longer appropriate.

(8) ACCOUNT MANAGEMENT | DYNAMIC ACCOUNT MANAGEMENT
Create, activate, manage, and deactivate [Assignment: organization-defined system accounts] dynamically.

(9) ACCOUNT MANAGEMENT | RESTRICTIONS ON USE OF SHARED AND GROUP ACCOUNTS

Only permit the use of shared and group accounts that meet [Assignment: organization-defined conditions for establishing shared and group accounts].

(11) ACCOUNT MANAGEMENT | USAGE CONDITIONS

Enforce [Assignment: organization-defined circumstances and/or usage conditions] for [Assignment: organization-defined system accounts].

(12) ACCOUNT MANAGEMENT | ACCOUNT MONITORING FOR ATYPICAL USAGE

(a) Monitor system accounts for [Assignment: organization-defined atypical usage]; and
(b) Report atypical usage of system accounts to [Assignment: organization-defined personnel or roles].

(13) ACCOUNT MANAGEMENT | DISABLE ACCOUNTS FOR HIGH-RISK INDIVIDUALS

Disable accounts of individuals within [Assignment: organization-defined time period] of discovery of [Assignment: organization-defined significant risks].

(14) IDENTIFIER MANAGEMENT

Control: Manage system identifiers by:

- a. Receiving authorization from [Assignment: organization-defined personnel or roles] to assign an individual, group, role, service, or device identifier;
- b. Selecting an identifier that identifies an individual, group, role, service, or device;
- c. Assigning the identifier to the intended individual, group, role, service, or device; and
- d. Preventing reuse of identifiers for [Assignment: organization-defined time period].

(15) IDENTIFIER MANAGEMENT | PROHIBIT ACCOUNT IDENTIFIERS AS PUBLIC IDENTIFIERS

Prohibit the use of system account identifiers that are the same as public identifiers for individual accounts.

(16) IDENTIFIER MANAGEMENT | IDENTIFY USER STATUS

Manage individual identifiers by uniquely identifying each individual as [Assignment: organization-defined characteristic identifying individual status].

(17) IDENTIFIER MANAGEMENT | DYNAMIC MANAGEMENT

Manage individual identifiers dynamically in accordance with [Assignment: organization-defined dynamic identifier policy].

(18) IDENTIFIER MANAGEMENT | CROSS-ORGANIZATION MANAGEMENT

Coordinate with the following external organizations for cross-organization management of identifiers: [Assignment: organization-defined external organizations].

(19) IDENTIFIER MANAGEMENT | PAIRWISE PSEUDONYMOUS IDENTIFIERS

Generate pairwise pseudonymous identifiers.

(20) IDENTIFIER MANAGEMENT | ATTRIBUTE MAINTENANCE AND PROTECTION

Maintain the attributes for each uniquely identified individual, device, or service in [Assignment: organization-defined protected central storage].

Authorisation of operation / assessment

A system **shall not enter operational service until**: (a) a security risk assessment (ECSS 5.4.1) has been completed; (b) identified residual risks are accepted by an Authorising Official (NIST CA-6).